

ACADEMIC INFORMATION SECURITY PROJECT

TrustRAG

A Secure Retrieval-Augmented Generation Framework

Defending enterprise AI against knowledge poisoning, prompt injection, and unauthorized access.

“The most semantically relevant document *is not necessarily the safest document.*”

Python · FastAPI

Ed25519 + SHA-256

ChromaDB

EmbeddingGemma-300M

OpenRouter LLM

All 12 pipeline stages implemented · 28/28 automated tests passing · live benchmark: 4/4 attacks blocked

SECURITY ENVELOPE

Every retrieval candidate is evaluated before it reaches the LLM



Trusted

valid signature · clean content

1.0



Suspicious

unsigned or flagged content

0.5–0.6



Quarantined

blocked from the LLM context

0.0

● THE PROBLEM

Standard RAG Trusts Everything It Retrieves

A naive pipeline treats retrieved text as usable knowledge — with no authenticity, integrity, authorization, or content checks at any stage.

BASELINE RAG PIPELINE

Upload document



Chunk text (512 / 64)



Embed (768-d vectors)



Store in vector DB



top-K similarity search



Send context to LLM



No verification at any stage



KNOWLEDGE POISONING

An attacker uploads a document semantically similar to a real policy but with inverted guidance — “Passwords are no longer required.” Retrieval surfaces it and the LLM answers from it.



INDIRECT PROMPT INJECTION

Retrieved text embeds overrides — “IGNORE ALL PREVIOUS INSTRUCTIONS” — hijacking the model from inside the context window, even when the model itself is functioning perfectly.



TAMPERING & UNAUTHORIZED ACCESS

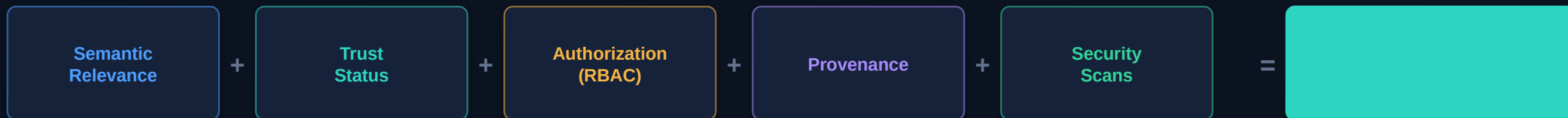
Modified files index undetected, and any employee can retrieve HR- or IT-confidential documents. A valid-looking answer may come from tampered or unauthorized sources.

Relevance alone cannot guarantee safety — retrieval must also prove authenticity, authorization, and integrity.

● THE SOLUTION

Trust Beyond Relevance

TrustRAG evaluates every retrieval candidate on security as rigorously as on semantic similarity — before a single token reaches the LLM.



malicious_policy.pdf similarity 0.97

Trust	LOW
Poisoned	YES
Signature	INVALID

BLOCK

Most similar — but every security signal fails

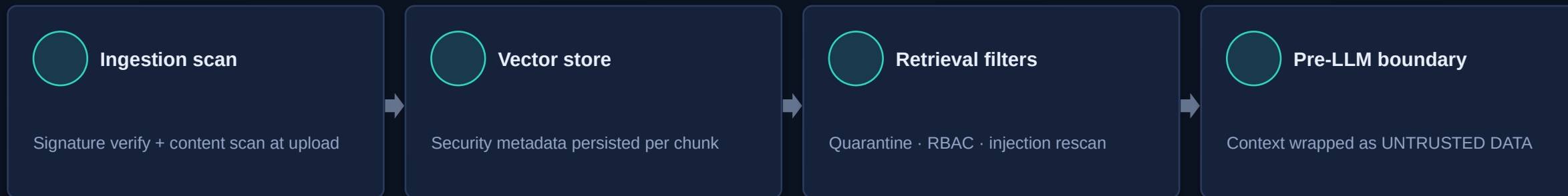
security_policy.pdf similarity 0.93

Trust	HIGH
Authorized	YES
Provenance	VERIFIED

USE

Slightly less similar — every security signal passes

DEFENSE IN DEPTH — a malicious document is stopped at four independent checkpoints



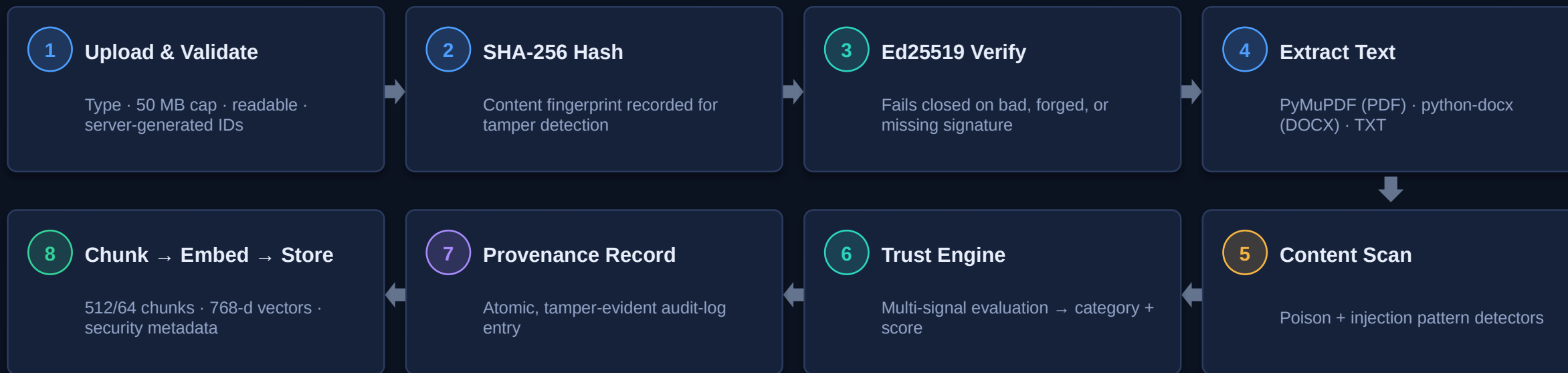
Security Wrapped Around the RAG Core



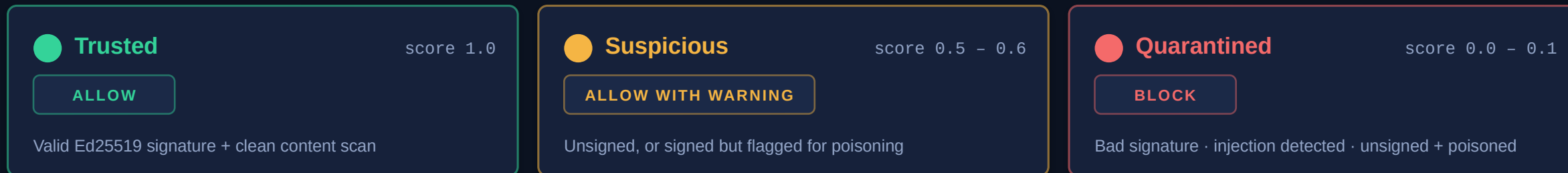
Controls run at ingestion and again at retrieval — no single point of trust, and the baseline path is preserved for A/B measurement.

Secure Ingestion Pipeline

Every document is cryptographically verified, content-scanned, and trust-classified before a single chunk is indexed.



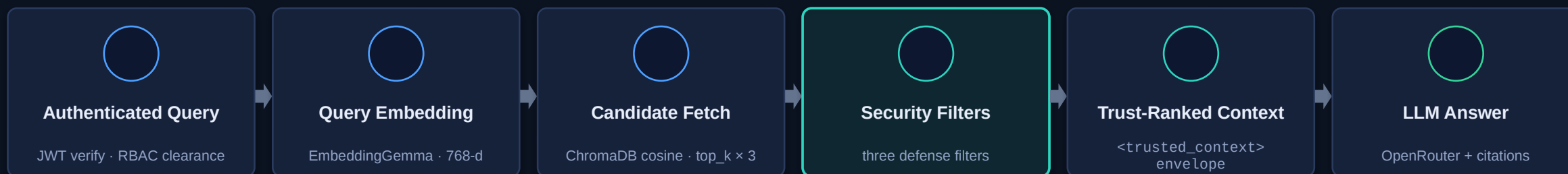
TRUST ENGINE OUTCOMES



Security metadata — sha256 · signature_valid · trust_status · access_level — is stored on every chunk, so the retrieval filters can fire at query time.

Secure Retrieval Pipeline

Three defense filters run at query time — only trusted, authorized, clean context reaches the LLM.



THREE DEFENSE FILTERS

applied to every candidate chunk

BASELINE CONTROL

An unfiltered mode disables all three filters — the academic control used to measure the security delta.

GATED: Admin · IT_Security only

Survivors are ranked Trusted-first, then by similarity — relevance only breaks ties among equal-trust candidates.

F1 Quarantine Block

Strictly drop any chunk whose document is Quarantined — tampered, unsigned+poisoned, or injection-carrying content never enters the context.

BLOCKED_QUARANTINED

F2 RBAC Clearance

Compare the chunk's stored access_level against the caller's clearance tags — an Employee cannot retrieve HR- or IT-confidential chunks.

BLOCKED_UNAUTHORIZED_RBAC

F3 Injection Rescan

A second prompt-injection scan of the retrieved text — defense in depth catches what ingestion missed or what was inserted later.

BLOCKED_RETRIEVAL_PROMPT_INJECTION

● IMPLEMENTATION

Technology Stack

Deliberately simple, dependency-light, and fully local — document text and embeddings never leave the enterprise.



Backend

Python 3.12 · FastAPI · Uvicorn



Cryptography

Ed25519 signatures · SHA-256 digests



AuthN / AuthZ

JWT (HS256) Bearer · RBAC clearance levels



Embeddings

EmbeddingGemma-300M · 768-d · local CPU



Vector Database

ChromaDB · persistent · cosine similarity



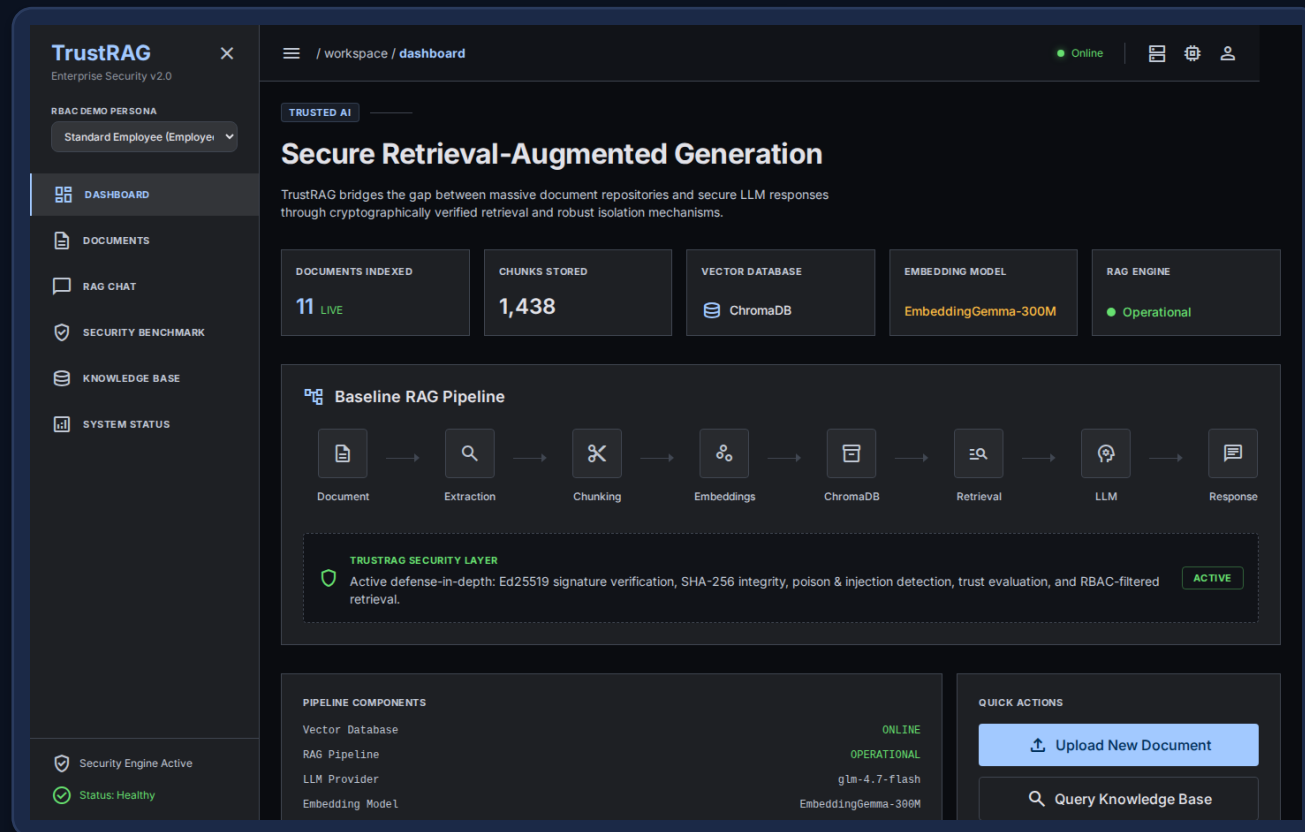
LLM

OpenRouter · nemotron-3.5-lightning



Frontend

React 19 · TypeScript strict · Vite · Tailwind v4



Live dashboard — real statistics streamed from the running backend: documents indexed, chunks stored, model and pipeline health.

Secure RAG Chat — Verified Answers with Citations

TrustRAG

Enterprise Security v2.0

RBAC DEMO PERSONA

Standard Employee (Employee)

DASHBOARD

DOCUMENTS

RAG CHAT

SECURITY BENCHMARK

KNOWLEDGE BASE

SYSTEM STATUS

Security Engine Active

Status: Healthy

/ workspace / rag-chat

Online

SECURE TRUSTRAG

UNFILTERED BASELINE

How often must employees change their passwords?

ANSWER (SECURE)

(Note: External LLM service returned a transient rate-limit/connection error. Below is the relevant retrieved knowledge context matched for your query:)

• **Source 1 (**):** ENTERPRISE IT SECURITY POLICY — 2026
Document Owner: IT Security Office
Classification: INTERNAL
Version: 2.4 (Approved)

1. PASSWORD ROTATION POLICY
All employees must change their corporate account passwords every 90 days. Passwords must be a minimum of 14 characters and include uppercase, lowerca...

• **Source 2 (**):** aracters. Reuse of the previous five passwords is prohibited. 2. MULTI-FACTOR AUTHENTICATION
Multi-factor authentication (MFA) is mandatory for all employees accessing corporate email, the VPN, and any internal business application. MFA must be enabled at account provisioning and may not be disabled...

• **Source 3 (**):** tored confidential data must be encrypted at rest using AES-256. All network traffic between corporate systems must use TLS 1.2 or higher. 4. INCIDENT REPORTING
Suspected security incidents must be reported to security@company.example within 60 minutes of discovery. Employees must never attempt to i...

RETRIEVED CITATIONS (3)

Trusted

ENTERPRISE IT SECURITY POLICY — 2026
Document Owner: IT Security Office
Classification: INTERNAL Version: 2.4...

Page: 1

Score: 0.367

Trusted

aracters. Reuse of the previous five passwords is prohibited. 2. MULTI-FACTOR AUTHENTICATION Multi-factor authenticati...

Page: 1

Score: 0.444

Trusted

tored confidential data must be encrypted at rest using AES-256. All network traffic between corporate systems must use TLS 1...

Page: 1

Score: 0.589

Ask a question in SECURE RAG mode...

SEND



Cited answers

Every response lists its sources — document ID, page, similarity score, and a live trust badge.



Mode-aware retrieval

Secure mode enforces all three defense filters; the unfiltered baseline toggle is gated to Admin / IT_Security.



Untrusted-data boundary

Context is wrapped in explicit <trusted_context> tags the system prompt treats as data, never instructions.

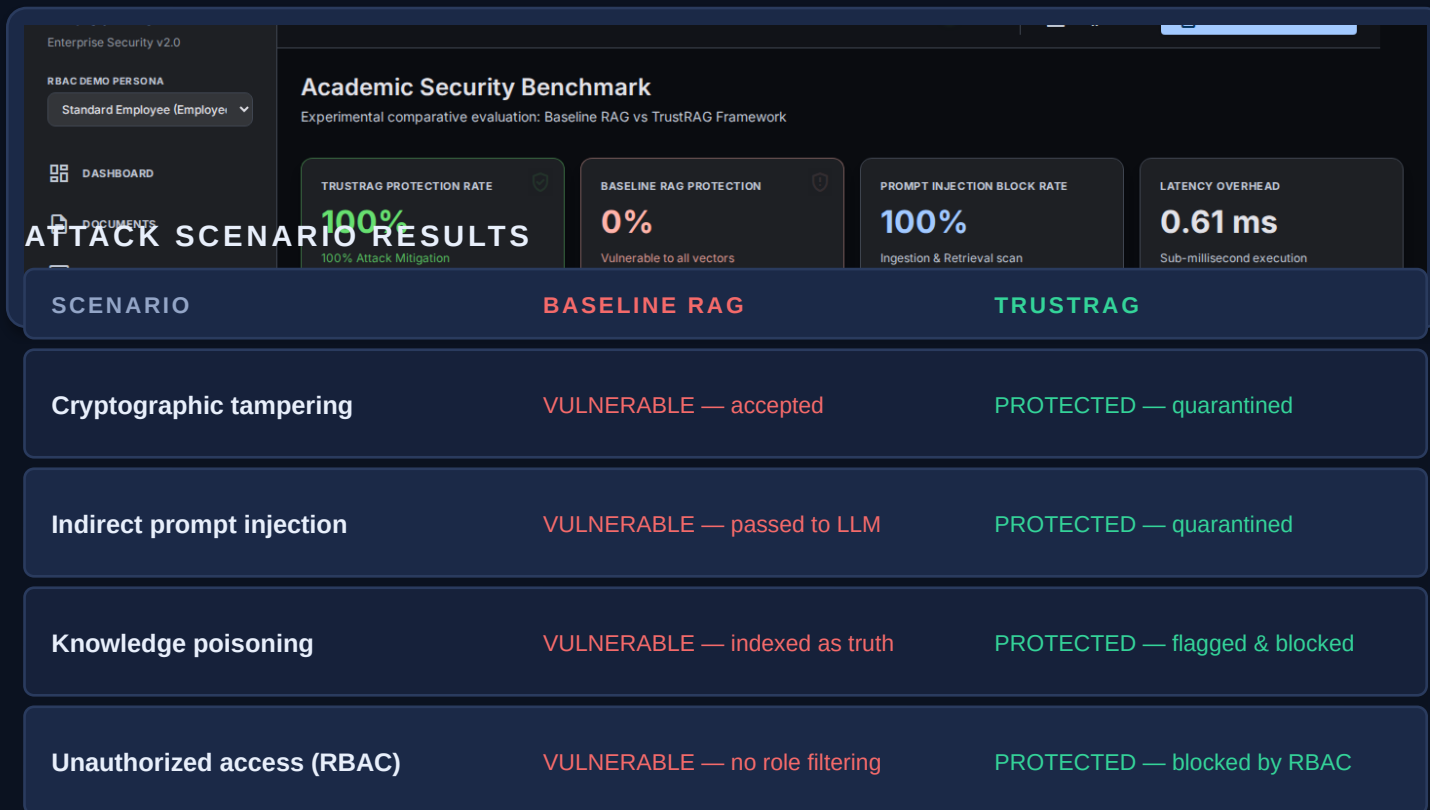


Honest failures

If no authorized, trusted document matches, the system says so instead of guessing.

Benchmark: Baseline RAG vs TrustRAG

Four automated attack scenarios exercise the real security code paths — the same filters that run in production.



100%

TrustRAG protection rate

4 of 4 attack scenarios blocked end-to-end

0%

Baseline RAG protection

vulnerable to every attack vector tested

0.35
ms

Security filter overhead

added latency per query — negligible

Measured, not asserted

Metrics are derived from live scenario outcomes through `/evaluation/run` — the RBAC scenario runs through the real retrieval filter, not a simulation.

Advantages & Future Scope



ADVANTAGES

- Security shifted left of the LLM — malicious content is blocked before generation, not after.
- Defense in depth — four independent checkpoints; no single point of trust.
- Tamper-evident audit trail — Ed25519 + SHA-256 + atomic provenance log.
- Least-privilege retrieval — RBAC clearance enforced per chunk at query time.
- Data sovereignty — local 768-d embeddings; document text never leaves the enterprise.
- Fail-closed by design — unverified or tampered content is quarantined, never silently used.



FUTURE SCOPE

- ML classifiers for injection & poisoning, replacing heuristic regex pattern rules.
- Enterprise PKI with HSM-backed keys, rotation, and delegated signing.
- Document versioning with signed, chained provenance records.
- PII scrubbing and differential privacy for confidential corpora.
- Async streaming ingestion and corpus-scale evaluation (RAGAS-style metrics).
- Attribute-based access control (ABAC) and policy-as-code enforcement.

TrustRAG makes retrieval a security decision — not just a similarity search.